



ICT Operations Guideline

Version: 2.0

Valid From Date: 19.08.2026

Last Review Date: 14.08.2026

Notes: This written rule uses gender-neutral and inclusive language. Whenever possible, the generic masculine is avoided and all employees of any gender identity (m/f/d) are addressed.

Content changes compared to the previous document version are highlighted in color.

Content

1. Purpose, Objectives and Basis	3
1.1. Purpose and Objectives	3
1.2. Basis of this Guideline	5
2. Functional Scope and Target Groups	6
2.1. Functional scope of applicability	6
2.2. Target groups	6
2.3. Transition period	7
3. Definitions	8
3.1. Requirements	8
3.2. Explanation of requirements and key definitions	9
4. Requirements	10
4.1. Requirement	10
4.1.1. Operations Management	10
4.1.2. Backup Management	20
4.1.3. ICT Service Continuity	25
4.1.4. System and Endpoint protection	34
5. Roles and Responsibilities	43
5.1. Creator	43
5.2. Guideline Owner	43
6. Appendix	44
6.1. Contact Information	44
6.2. Document History	44
6.3. Related Written Rules	44
6.4. Abbreviations	45

1. Purpose, Objectives and Basis

1.1. Purpose and Objectives

The ICT Operations Guideline (hereinafter “Guideline”) establishes control requirements for DBAG and/or adopting Legal Entities within DBG (refers only to Legal Entities that have ratified the Guideline at hand) and provides criteria for fulfilling the control requirements.

The purpose of the Guideline is to effectuate the below listed Minimum Requirements, stipulated in the ICT Risk Management Policy (structured into Core Functions), acting as objectives to the Guideline and the control requirements at hand:

Core Function	Minimum Requirement	ICT Risk Management Policy chapter
Govern	2. Allocate roles and responsibilities as detailed in chapter 5 in the ICT Risk Management Policy.	4.1
Govern	6. Have in place a mechanism to define and document responsibilities for implementing control requirements both within and outside IT and IS (e.g. HR). This can be documented e.g. as part of the ICT Control Framework (former Mandatory Control Framework (MCF)) .	4.1
Protect	1. Design and implement ICT risk management control requirements to achieve the protection goals and integrating them to the ICT Written Rules framework. These control requirements are including but not limited to ICT operations and physical and environmental security, network and infrastructure management, encryption and cryptographic controls, identity management and logical/physical access control, software development, change and project management, threat management, patch and vulnerability management, human resources, and third-party management, AI, IDP & NCLC¹, data management and other controls addressing poor administration and human error risks .	4.3
Protect	3. Put in place information transfer rules, procedures, or agreements for all types of transfer facilities within the	4.3

¹ IDP refers to Individual Data Processing, and NCLC refers to No-Code/Low-Code solutions.

	organization and between the organization and other parties.	
Protect	6. Protect information stored on, processed by or accessible via user endpoint devices.	4.3
Respond	2. Define, implement, and test response processes and mechanisms to ensure ICT-related incident containment, to prevent expansion of an event and mitigate its effects.	4.5
Respond	5. Plan how to maintain ICT security at an appropriate level during disruption.	4.5
Recover	1. Define, execute, and regularly test continuity and recovery plans to recover from ICT-related incidents in a way that limits damage and prioritizes the continuation and resumption of activities.	4.6
Recover	2. Plan, implement, maintain, and test ICT readiness based on business continuity objectives and ICT continuity requirements.	4.6
Recover	3. Implement ICT processing facilities with redundancy sufficient to meet availability requirements.	4.6
Recover	4. Define, implement, and regularly test backup processes and methods ensuring the restoration of assets and data within Recovery Time Objective (RTO), ensuring appropriate minimum downtime, limited disruption and loss.	4.6
Learn and evolve	6. Monitor the use of resources and adjust them in line with current and expected capacity requirements.	4.7
Communicate	1. Set out communication and crisis management actions to ensure that updated information is transmitted to all relevant internal staff and external stakeholders and reported to the competent authorities upon their request.	4.8

Table 1: Minimum Requirements

Note: The full list of Core Functions and Minimum Requirements is stipulated in the ICT Risk Management Policy.

1.2. Basis of this Guideline

The basis for this Guideline is the thematically linked ICT Risk Management Policy.

2. Functional Scope and Target Groups

2.1. Functional scope of applicability

Entity	DBAG or adopting LE within DBG
Area	DBAG CIO / COO Division; Chief Risk Officer Area; or any other area that manages or owns ICT Operations topic

Table 2: Scope

2.2. Target groups

Within the scope of the current ICT Operations Guideline below is addressed the list of applicable target groups and operation areas²:

Target group	Key message
ICT Risk Oversight	To oversee and to develop the ICT operations Guideline and practices. To provide analysis and reports on the adequacy and effectiveness of ICT operations (including internal control).
ICT Operational Management	To implement and maintain appropriate structures, processes, measures, and controls for the effective ICT operations (including internal control).
Business Management	Leads and directs actions and application of resources to achieve the objectives of the organization. To be accountable for the of ICT operations related risks affecting their business function or process. To decide on risk treatment (accept, transfer, avoid or mitigate the risk).
	Leads and directs actions and application of resources to achieve the objectives of the organization (incl. ICT operations related risks).
Management Body	To ensure the awareness of the importance of ICT operations for strategic decision-making.

Table 3: Target groups

² For LE Guidelines adoption process the target groups should be adjusted according to organizational structure of the LE.

2.3. Transition period

The grace period for new requirements commences from the “valid from” date stated on the cover page. The compliance dates for control requirements defined in this version of the Guideline are defined as follows:

- For unchanged control requirements and new DORA requirements the compliance date equals the “valid from” date.
- For new and changed control requirements that are more stringent than before and are not subject to DORA, the compliance date is generally 90 calendar days after the “valid from” date unless otherwise stated in brackets after the control requirements. These control requirements are marked with ●.
- For Legal Entities that have not previously approved the IT-related requirements and are therefore addressing these requirements for the first time, a grace period of 90 days may be granted at the discretion of the Legal Entity. DORA requirements are exempt from this grace period.

For a **compliance date** exceeding a 180 calendar days implementation timeline, a Board approval is required.

3. Definitions

3.1. Requirements

Control requirement

The control requirements define the organizational, process or technical controls to be implemented by the control owner to achieve compliance with this Guideline.

Criteria

Criteria define the measures that 'must' or 'should' be taken to fulfill the control requirement.

Level of obligation

With respect to requirements and criteria, the following terms are used to define the level of obligation, provided for the implementation of a particular requirement or criteria:

- **“must”**: Mandatory control requirements / criteria derived directly from law, regulations, or internal specifications that the legal entity must comply with. Incompliance could result in consequences with external regulators and Internal Audit.
- **“should”**: Non-mandatory control requirements / criteria derived from best-practice frameworks or equivalent sources that the legal entity does not have to necessarily comply with. Under specific circumstances there may exist valid reasons to ignore a particular control requirement, but the full implications must be understood and carefully weighed.

Independent of the level of obligation of a given requirement or criteria, it is allowed to deviate from single requirements or criteria in individual cases. However, a control requirement deviation always requires the conduction of a risk assessment and risk management including adequate risk acceptance and/or mitigation.

Any deviation from the Guideline denotes an exemption. The respective Information Owner makes decisions on such exemptions. Information Owners can only decide on risks with impact exclusively in their area of responsibility.

Responsibilities

The responsibility for fulfilling control requirements may be distributed across the organization, e.g., multiple Sections, Units, or Departments. In some cases, one Unit may be responsible for both the design and implementation of measures. In other cases, one Unit may be responsible for the design of measures, and another Unit may be responsible for the implementation of the measures. In addition, multiple Units may be responsible to collectively fulfill one requirement.

The precise responsibilities are to be defined in the underlying Procedure documents (e.g. via RACI matrices).

The ICS, among its various functionalities, registers Process Operators (PO) and Risk Representatives (RRs) mapped to the corresponding processes, controls, and risks which the RRs and/or POs are responsible for managing on behalf of the part of the organization that utilize their services (e.g. Asset Owners). For more information on ICS, please refer to the DBG ICS Guideline.

3.2. Explanation of requirements and key definitions

Control requirements are defined in a standardized format and are structured into the following components:

<Specify ID: xx (version x)>	<Name of control requirement (e.g. Access to production data)>
1	<Description of the control requirement>
1.1 1.1.1	<Lists the criteria applying to the control requirement> <Lists the sub-criteria applying to the control requirement> Asset-Types: <Lists asset types applicable to the control requirement> Key references: <Lists key regulatory references and industry best practice requirements affecting this control requirement (e.g., ISO/IEC 27001:2022 A.5.10, A.8.1)>

The terms in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

4. Requirements

4.1. Requirement

4.1.1. Operations Management

ID: 1 (version 2.0)	ICT Operations
1 DOR.ICT.OPS.PRC.001	It must be ensured that ICT operations and its activities are managed.
1.1 DOR.ICT.OPS.PRC.002	Procedures and processes must be developed and documented to manage ICT operations. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.8.1
1.2 DOR.ICT.OPS.PRC.003	Those procedures and processes must specify how IT Assets are operated, monitored, controlled, restored, and documented. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.8.1

ID: 2 (version 2.0)	Roles and responsibilities
2 DOR.ICT.OPS.ROR.001	It must be ensured that roles and responsibilities for ICT operations are defined.
2.1 DOR.ICT.OPS.ROR.002	Roles and responsibilities must be defined for ICT Operations. Asset-Types: Business Process, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.20
2.2 DOR.ICT.OPS.ROR.003	Segregation of duties must be defined and implemented where applicable. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.20

ID: 3 (version 2.0)	Asset description
3 DOR.ICT.OPS.ASD.001	It must be ensured that specifications for IT Assets and non-IT Assets are described.
3.1 DOR.ICT.OPS.ASD.002	A description for IT Assets and, where applicable, non-IT Assets must be in place including: – Specifications for the secure installation, maintenance, configuration, and de-installation of an ICT System – Specifications for the management of Information Assets used by IT Assets and non-IT Assets, including their processing and handling, both automated and manual; – Specifications for the identification and control of legacy ICT Systems; Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.8.2a)

ID: 4 (version 2.0)	ICT System Reliability and Resilience
4 DOR.ICT.OPS.SYS.001	It must be ensured that ICT Systems are reliable and technologically resilient under stressed market conditions or other adverse circumstances.
4.1 DOR.ICT.OPS.SYS.001	ICT Systems, protocols, and tools must be reliable and technologically resilient, ensuring their capability to handle increased information processing demands under stressed market conditions or other adverse circumstances. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA 2022/2554 A.7.b), A.7.d)

ID: 5 (version 2.0)	Availability Management
5 DOR.ICT.OPS.AVM.001	It must be ensured that the availability of IT Assets is managed.
5.1 DOR.ICT.OPS.AVM.002	Availability procedures must be developed and in place. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.9.1
5.2 DOR.ICT.OPS.AVM.003	Availability requirements for IT Assets must be defined based on their criticality and business requirements. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.6
5.3 DOR.ICT.OPS.AVM.004	If the existing system architecture cannot ensure the requirements on the availability of the IT Assets, it must be achieved by implementing redundant components or architectures. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.14
5.4 DOR.ICT.OPS.AVM.005	To ensure integrity and handle the complexity of infrastructure, legal entities must control redundancy: – Ensure information processing is implemented with redundancy sufficiency to meet availability requirements – Ensure protection of redundant components at the same level or higher as their primary counterparts – Redundant information systems must be tested to ensure the failover from one component to another component works as intended. Tests must be performed regularly, following a risk-based approach, and after significant changes. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.14

ID: 6 (version 2.0)	Capacity Management
6 DOR.ICT.OPS.CAP.001	It must be ensured that the capacity of IT Assets is managed.
6.1 DOR.ICT.OPS.CAP.002	Capacity requirements for IT Assets must be defined depending on the criticality of their availability. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.6
6.2 DOR.ICT.OPS.CAP.003	ICT Systems must be designed and maintained with sufficient capacity to ensure accurate data processing and timely service delivery under both normal and peak workloads, including during the deployment of new technologies. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 A.8.6
6.3 DOR.ICT.OPS.CAP.004	To ensure continuity of critical business operations in the event of system failures or disruptions, redundant IT Assets and non-IT Assets equipped with the necessary resources and capabilities must be in place and operational. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection, Supplier, Building, Datacenter Key References: DORA 2022/2554 A.12.4
6.4 DOR.ICT.OPS.CAP.005	Capacity thresholds must be defined, based on system design, projections, availability criticality of concerned systems, regulations, expected requirements of business development (including current and projected trends) and procurement lead times for additional capacity. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203
6.5 DOR.ICT.OPS.CAP.006	ICT Systems should be running within capacity thresholds. Measures should be taken to ensure these thresholds are not exceeded to avoid service interruptions. Furthermore, resource optimisation should be applied to ensure that these thresholds apply to the right resource mix. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other

	Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.6
6.6 DOR.ICT.OPS.CAP.007	For systems supporting critical or important functions, a dedicated capacity management plan tailored to each specific IT Application or ICT System must be established. Appropriate measurement units must be defined, monitored, and reported. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.6
6.7 DOR.ICT.OPS.CAP.008	ICT Systems with long or complex procurement procedures, approval processes or those that are resource-intensive must be appropriately managed and prioritized, reflecting their specific operational and risk-related characteristics. Asset-Types: Business Process Key References: DORA RTS RMF A.9.2

ID: 7 (version 2.0)	Availability and Capacity Monitoring
7 DOR.ICT.OPS.CPM.001	It must be ensured that availability and capacity management is monitored.
7.1 DOR.ICT.OPS.CPM.002	The use of IT infrastructure resources must be monitored, and those results used to make projections regarding future capacity need. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.6
7.2 DOR.ICT.OPS.CPM.003	Root causes for availability and capacity issues must be identified in a timely manner and resolved in accordance with a pre-defined timeline. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ICT Risk Framework 1.0
7.3 DOR.ICT.OPS.CPM.004	Automated controls must be implemented and defined by Asset Owners to indicate potential problems in a timely manner. Where appropriate, an incident process should be triggered automatically in case systems have reached defined capacity thresholds. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host

	Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.6
7.4 DOR.ICT.OPS.CPM.005	Job scheduling must be carried out with consideration for the operational requirements and dependencies of IT Assets. Asset-Types: Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ICT Risk Framework 1.0
7.5 DOR.ICT.OPS.CPM.006	Audit and review activities must be planned to minimize disruptions to ICT Systems and business processes. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.35

ID: 8 (version 2.0)	Error handling
8 DOR.ICT.OPS.ERH.001	It must be ensured that errors during job execution are identified and handled.
8.1 DOR.ICT.OPS.ERH.002	Mechanisms to identify and handle errors during job execution must be developed and documented. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ICT Risk Framework 1.0
8.2 DOR.ICT.OPS.ERH.003	In case of unexpected operational, technical issues or errors support and escalation contacts must be in place. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.8.2c.ii)
8.3 DOR.ICT.OPS.ERH.004	Errors during job execution that could not be fixed automatically must be addressed and followed up manually in accordance with the ICT Incident and Operational Event Management Guideline. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ICT Risk Framework 1.0

ID: 9 (version 2.0)	Logging
9 DOR.ICT.OPS.LOG.001	It must be ensured that all ICT System transactions and all monitoring and operating events are logged in a way which cannot be changed by the operators.
9.1 DOR.ICT.OPS.LOG.002	Records must be kept of all suspected or actual faults, and of all preventive and corrective maintenance, for a period determined by applicable requirements and local laws. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ICT Risk Framework 1.0
9.2 DOR.ICT.OPS.LOG.003	Events related to capacity management, ICT operations and ICT System activities must be logged according to the ICT Incident & Operational Event Management Guideline.

	Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.12.2.c).ii, A.12.2.c).iv
9.3 DOR.ICT.OPS.LOG.004	Audit-trail and system log information of ICT Systems must be recorded. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.8.2b.iii)

ID: 10 (version 2.0)	Documentation
10 DOR.ICT.OPS.DOC.001	It must be ensured that formal documentation and operating handbooks are in place.
10.1 DOR.ICT.OPS.DOC.002	Operating handbooks must be developed, documented, and maintained. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.37
10.2 DOR.ICT.OPS.DOC.003	The operating handbooks should include descriptions of at least the following procedures: – Start, restart, recovery, and deactivation of the system – Configuration of the system, including default and actual used values – Processing and handling of information – Data and system backup process and restoration – Description of standard changes – Error handling – Exceptional situations instructions – Support and escalation procedures – Special output and media handling, such as management of strictly confidential output including procedures for secure disposal of output from failed jobs – Management of audit-trail and system log information – Description of the access management model – Monitoring procedures Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.37
10.3 DOR.ICT.OPS.DOC.004	Documentation of dependencies and interfaces between ICT Systems must be in place. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.37
10.4 DOR.ICT.OPS.DOC.005	Operating procedures must be reviewed at defined intervals or whenever significant changes to the system are implemented. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage,

	Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.37
--	---

ID: 11 (version 2.0)	Software management
11 DOR.ICT.OPS.SOF.001	It must be ensured that software usage and installation is managed.
11.1 DOR.ICT.OPS.SOF.002	Software installation must be a defined and documented process. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.19
11.2 DOR.ICT.OPS.SOF.003	It must be ensured that only approved and licensed software is installed. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.19
11.3 DOR.ICT.OPS.SOF.004	The list of approved software must be documented. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.19
11.4 DOR.ICT.OPS.SOF.005	The principles of least privilege must be applied for restricting the installation of software on information systems. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.19
11.5 DOR.ICT.OPS.SOF.006	Processes and process-supporting tools must be implemented which sufficiently monitor the system capacities (resources) and foster availability. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.6

4.1.2. Backup Management

ID: 12 (version 2.0)	Backup and Recovery Management
12 DOR.ICT.OPS.BRM.001	It must be ensured that comprehensive and secure backup, restoration, and recovery procedures are established.
12.1 DOR.ICT.OPS.BRM.002	Backup procedures must be developed and documented, clearly defining the scope of the data to be backed up and the minimum backup frequency, considering the data's confidentiality and criticality. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.39.2.g)
12.2 DOR.ICT.OPS.BRM.003	Restoration and recovery procedures and methods must be developed and documented. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.26.1.d)
12.3 DOR.ICT.OPS.BRM.004	Both procedures and methods must be based on a risk assessment and ensure coverage of all critical data and systems. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA 2022/2554 Article 12, ISO/IEC 27001:2022 A.8.1
12.4 DOR.ICT.OPS.BRM.005	Both procedures and methods must be tested at defined regularly but at least every 12 months or after significant changes. Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA 2022/2554 A.12.1
12.5 DOR.ICT.OPS.BRM.006	All restoration activities must meet predefined Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO). Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA 2022/2554 A.12.6

12.6 DOR.ICT.OPS.BRM.007	Backups must include all relevant asset data, information, software, configuration, and system images and must be stored and be restorable in accordance with the restoration and recovery procedures. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.13
12.7 DOR.ICT.OPS.BRM.008	Backup data must be classified according to its protection level and stored in alignment with that classification. Asset-Types: Information, Business Process, Cloud Appliance, Cloud PaaS, Container, Storage Media, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.13
12.8 DOR.ICT.OPS.BRM.009	Backup data must be protected depending on their classification using cryptographic measures. Encryption keys must be securely managed in accordance with the Encryption and Key Management Guideline. Asset-Types: Information, Business Process, Cloud Appliance, Cloud PaaS, Container, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.13
12.9 DOR.ICT.OPS.BRM.010	In the event of disruption, recovery procedures must ensure that all necessary transactions can be restored and enable the completion of settlement on the scheduled date. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA 2022/2554 A.12.3

ID: 13 (version 2.0)	Backup systems
13 DOR.ICT.OPS.BSY.001	It must be ensured that backup systems are established, secured, and capable of being activated in accordance with defined procedures.
13.1 DOR.ICT.OPS.BSY.002	Backup systems must be implemented in a way that allows activation in accordance with backup procedures, restoration and recovery procedures and methods. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: DORA 2022/2554 A.12.2
13.2 DOR.ICT.OPS.BSY.003	The activation of backup systems must not compromise the security of network and information systems, nor affect confidentiality, integrity, availability or authenticity the data.

	Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA 2022/2554 A.12.2
13.3 DOR.ICT.OPS.BSY.004	ICT Systems used for backup restoration must be physically and logically segregated from the source ICT Systems to prevent compromise in the event of a cyber incident or system failure. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA 2022/2554 A.12.3

ID: 14 (version 2.0)	Backup facilities
14 DOR.ICT.OPS.BFA.001	It must be ensured that backup facilities are in place.
14.1 DOR.ICT.OPS.BFA.002	Backup facilities equipped with sufficient resources, capabilities and functions to fulfil business needs and ensure continuous service availability must be maintained. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, Storage Media, Other Device, Storage, Server & Host Hardware Key References: DORA 2022/2554 A.12.5

ID: 15 (version 2.0)	Asset backup handling
15 DOR.ICT.OPS.ABH.001	It must be ensured that the backup after removal and disposal of an IT Asset is managed.
15.1 DOR.ICT.OPS.ABH.002	In case of removal or disposal of IT assets it must be ensured that the backup for the removed or disposed IT Assets is handled according to requirements of the Information Owner (for more information check the ICT Asset Management Guideline). Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage, Server & Host Hardware, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.13

ID: 16 (version 2.0)	Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO)
16 DOR.ICT.OPS.RTO.001	It must be ensured that RTOs and RPOs are defined and adhered to for all relevant functions and IT Assets.
16.1 DOR.ICT.OPS.RTO.002	The determination of RTOs and RPOs must consider whether the function is critical or important, as well as the potential overall impact on market efficiency, agreed by the Asset Owner and documented in the Asset Inventory (according to the ICT Asset Management Guideline). Asset-Types: Information, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage Media, Storage, Server & Host Hardware Key References: DORA 2022/2554 A.12.6
16.2 DOR.ICT.OPS.RTO.003	All information systems, IT Applications, and data of the legal entity must be backed up in a way to ensure that the RPO objective is met. Depending on the RPO levels following must be fulfilled: – RPO = 0 (Impact on Availability Criticality Level: “Critical”): Remote synchronous replication for RPO = 0 minutes and backup restore point and redo logs – 0h < RPO < 1h (Impact on Availability Criticality Level: “Critical”): Remote asynchronous replication for RPO < 1 hour but not 0 minutes (e.g. RPO = 15, 20 or 30 minutes) and backup restore point and redo logs + daily backup or alternative measures which guarantee no / minimum data loss – 1h ≤ RPO < 4h (Impact on Availability Criticality Level: “Major”): daily backup (full or incremental) + every x hours during business hours redo logs / snapshots / backups or alternative solution guaranteeing RPO – 4 h ≤ RPO < 1 day (Impact on Availability Criticality Level: “Minor”): daily backup (full or incremental) + every x hours during business hours redo logs / snapshots / backups or alternative solution guaranteeing RPO – RPO of 1 day or more (Impact on Availability Criticality Level: “Negligible”): weekly backup + daily (incremental) backups Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.13
16.3 DOR.ICT.OPS.RTO.004	The RTO for mission-critical functions must not be longer than two hours. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage Media, Storage, Server & Host Hardware Key References: DORA RTS RMF A.24.2a)
16.4 DOR.ICT.OPS.RTO.005	Trading venues must resume trading within or close to two hours of a disruptive incident, irrespective of the function's criticality or importance, with data loss from IT services minimized to near zero.

	Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage Media, Storage, Server & Host Hardware, Supplier Key References: DORA RTS RMF A.24.4a)
--	--

ID: 17 (version 2.0)	Continuous Improvement
17 DOR.ICT.OPS.BIM.001	It must be ensured that the backup procedures are reviewed and improved.
17.1 DOR.ICT.OPS.BIM.002	At least once a year, the efficiency and completeness of backup procedures should be validated. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.5.37
17.1.1 DOR.ICT.OPS.BIM.003	This involves demonstrating the successful restoration of an IT service following a failure, using a risk-based approach. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.37
17.1.2 DOR.ICT.OPS.BIM.004	The outcomes of validating the backup procedures must be recorded in a report. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.37

4.1.3. ICT Service Continuity

ID: 18 (version 2.0)	ICT Service Continuity Plans
18 DOR.ICT.OPS.SCP.001	ICT service continuity plans, procedures and mechanisms must be designed and implemented.
18.1 DOR.ICT.OPS.SCP.002	ICT service continuity plans, procedures and processes must be developed, tested, reviewed, and implemented. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA 2022/2554 A.11.3
18.2 DOR.ICT.OPS.SCP.003	Based on BIA results specific activation, deactivation and exception criteria for the ICT service continuity plans must be established. Asset-Types: Business Process Key References: DORA RTS RMF A.24.1.a) iv.
18.3 DOR.ICT.OPS.SCP.004	ICT service continuity plans must include: Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.26.1
18.3.1 DOR.ICT.OPS.SCP.005	Actions that need to be taken to ensure availability, integrity, continuity, and recovery of at least ICT Systems and services supporting critical or important functions. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA 2022/2554 A.11.2a)
18.3.2 DOR.ICT.OPS.SCP.006	Structure to limit the damage and meet the defined RTOs and RPOs. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.26.1c)
18.3.3 DOR.ICT.OPS.SCP.007	Specific containment measures and technologies suitable for each type of incident to minimize the impact.

	Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA 2022/2554 A.11.2c)
18.3.4 DOR.ICT.OPS.SCP.008	Quick estimation of preliminary impacts, damages, and losses upon activation of plans. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA 2022/2554 A.11.2d)
18.3.5 DOR.ICT.OPS.SCP.009	Prioritization of ICT Service Continuity actions on a risk-based approach. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.24.1biii)
18.3.6 DOR.ICT.OPS.SCP.010	Definition of clear roles and responsibilities. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.26.1
18.3.7 DOR.ICT.OPS.SCP.011	Short-term and long-term recovery options including partial system recovery. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.26.1e)
18.3.8 DOR.ICT.OPS.SCP.012	Objectives and the conditions for successful execution. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.26.1f)
18.3.9 DOR.ICT.OPS.SCP.013	Available documentation for relevant users also in case of emergency. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End

	User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.26.1d)
18.3.10 DOR.ICT.OPS.SCP.014	Acceptable loss to availability of information and services, in the event of a disaster. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.29, A.5.30
18.3.11 DOR.ICT.OPS.SCP.015	Implementation and maintenance of ICT risk framework or compensating controls, in the event of a disaster. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.29, A.5.30
18.3.12 DOR.ICT.OPS.SCP.016	Emergency procedures, manual fallback plans, and resumption plans to restore the infrastructure services. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.29, A.5.30
18.4 DOR.ICT.OPS.SCP.017	The plans must consider alternative options if the primary recovery measures may not be feasible in the short-term due to costs, risks, logistics, or unforeseen circumstances. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.26.3
18.5 DOR.ICT.OPS.SCP.018	The plans must consider and implement continuity measures to mitigate failures of ICT third-party service providers of ICT services supporting critical or important functions. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.26.3

18.6 DOR.ICT.OPS.SCP.019	Relevant documentation that supports the ICT service continuity plans must be developed, identified, acquired, made available to authorized stakeholders and reviewed periodically. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: CSA CCM BCR05
18.7 DOR.ICT.OPS.SCP.020	The ICT service continuity plans must be updated at defined intervals. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ICT Risk Framework 1.0

ID: 19 (version 2.0)	ICT Service Continuity Plans Testing
19 DOR.ICT.OPS.CPT.001	It must be ensured that ICT service continuity plans as well as procedures are appropriately tested.
19.1 DOR.ICT.OPS.CPT.002	It must be ensured that ICT service continuity plans are tested at least annually or after a significant change to ICT Systems supporting critical or important functions. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA 2022/2554 A.11.6a)
19.2 DOR.ICT.OPS.CPT.003	The tests must include procedures to verify that personnel, third party ICT service providers, ICT Systems and services respond to failure scenarios by achieving the defined RTOs and RPOs. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.25.2e)
19.3 DOR.ICT.OPS.CPT.004	Those tests must consider results of the Business Impact Analysis (BIA) and ICT Risk Assessment (for details refer to ICT Risk Management Guideline). Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile

	Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.25.1, A.26.2
19.4 DOR.ICT.OPS.CPT.005	It must be ensured that all IT assets supporting critical functions or having the highest availability requirements, as identified by the BIA, are included in the scope of annual testing. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.25.1
19.5 DOR.ICT.OPS.CPT.006	Testing must be based on possible failure scenarios which must be developed using current information of threats and on lessons learned from previous business interruptions including severe business disruptions and increased likelihood of occurrence of disruption. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.26.2
19.6 DOR.ICT.OPS.CPT.007	Following scenarios must be considered: – Cyber-attacks and switchovers between the primary ICT infrastructure and the redundant capacity, backups, and redundant facilities. – Scenarios in which the quality of the provision of a critical or important function deteriorates to an unacceptable level or fails – Scenarios linked to insolvency or failures of ICT third-party service providers. – Partial or total failure of premises including office and business premises and data centers. – Substantial failure of IT assets or of the communication infrastructure. – The non-availability of a critical number of staff or staff members in charge of guaranteeing the continuity of operations. – Impact of climate change and environment degradation related events, natural disasters, pandemic, and physical attacks, including intrusions and terrorist attacks. – Insider attacks. – Political and social instability, including, where relevant, in the jurisdiction from where the ICT third-party service provider provides its services and the location where the data is stored and processed. – Widespread power outages. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Mobile Device, Other Device, Storage, Server & Host Hardware, Network Connection, Supplier, Building, Room, Datacenter Key References: DORA RTS RMF A.26.2
19.7 DOR.ICT.OPS.CPT.008	The scenarios must be regularly updated and reviewed.

	Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ICT Risk Framework 1.0
19.8 DOR.ICT.OPS.CPT.009	Tests of ICT service continuity plans must be designed to challenge the assumptions and scenarios on which the plans are based on, including governance arrangements and crisis communication plans. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.25.2d)
19.9 DOR.ICT.OPS.CPT.010	The tests must include procedures to verify that personnel, third party ICT service providers, ICT Systems and services respond appropriately to the possible failure scenarios. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.25.2)e
19.10 DOR.ICT.OPS.CPT.011	Testing the ICT service continuity plan must include the involvement of appropriate participation of stakeholders, external providers, and relevant institutions. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.25.3, A.25.4
19.11 DOR.ICT.OPS.CPT.012	Test results must be documented, and any deficiencies must be analyzed, managed, followed-up, timely resolved, and reported to management. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.25.5

ID: 19 (version 1.1)	ICT Service Continuity Plans Testing
19 DOR.ICT.OPS.CPT.001	It must be ensured that ICT service continuity plans as well as procedures are appropriately tested.
19.1 DOR.ICT.OPS.CPT.002	It must be ensured that ICT service continuity plans are tested at least annually or after a significant change to ICT Systems supporting critical or important functions. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA 2022/2554 A.11.6a)
19.2 DOR.ICT.OPS.CPT.003	The tests must include procedures to verify that personnel, third party ICT service providers, ICT Systems and services respond to failure scenarios by achieving the defined RTOs and RPOs. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.25.2e)
19.3 DOR.ICT.OPS.CPT.004	Those tests must consider results of the Business Impact Analysis (BIA) and ICT Risk Assessment (for details refer to ICT Risk Management Guideline). Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.25.1 Key References: DORA RTS RMF A.26.2
19.4 DOR.ICT.OPS.CPT.005	Testing must be based on possible failure scenarios which must be developed using current information of threats and on lessons learned from previous business interruptions including severe business disruptions and increased likelihood of occurrence of disruption. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.26.2
19.5 DOR.ICT.OPS.CPT.006	Following scenarios must be considered: – Cyber-attacks and switchovers between the primary ICT infrastructure and the redundant capacity, backups, and redundant facilities.

	– Scenarios in which the quality of the provision of a critical or important function deteriorates to an unacceptable level or fails – Scenarios linked to insolvency or failures of ICT third-party service providers. – Partial or total failure of premises including office and business premises and data centers. – Substantial failure of IT assets or of the communication infrastructure. – The non-availability of a critical number of staff or staff members in charge of guaranteeing the continuity of operations. – Impact of climate change and environment degradation related events, natural disasters, pandemic, and physical attacks, including intrusions and terrorist attacks. – Insider attacks. – Political and social instability, including, where relevant, in the jurisdiction from where the ICT third-party service provider provides its services and the location where the data is stored and processed. – Widespread power outages. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Mobile Device, Other Device, Storage, Server & Host Hardware, Network Connection, Supplier, Building, Room, Datacenter Key References: DORA RTS RMF A.26.2
19.6 DOR.ICT.OPS.CPT.007	The scenarios must be regularly updated and reviewed. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ICT Risk Framework 1.0
19.7 DOR.ICT.OPS.CPT.008	Tests of ICT service continuity plans must be designed to challenge the assumptions and scenarios on which the plans are based on, including governance arrangements and crisis communication plans. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.25.2d)
19.8 DOR.ICT.OPS.CPT.009	The tests must include procedures to verify that personnel, third party ICT service providers, ICT Systems and services respond appropriately to the possible failure scenarios. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.25.2)e

19.9 DOR.ICT.OPS.CPT.010	Testing the ICT service continuity plan must include the involvement of appropriate participation of stakeholders, external providers, and relevant institutions. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.25.3, A.25.4
19.10 DOR.ICT.OPS.CPT.011	Test results must be documented, and any deficiencies must be analyzed, managed, followed-up, timely resolved, and reported to management. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.25.5

4.1.4. System and Endpoint protection

ID: 20 (version 2.0)	Data and ICT System Security Procedures
20 DOR.ICT.OPS.PRO.001	It must be ensured that data and ICT System security procedures are in place.
20.1 DOR.ICT.OPS.PRO.002	Procedures to secure data and ICT Systems must be developed, documented, and implemented. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.11.1
20.2 DOR.ICT.OPS.PRO.003	Those data and ICT System security procedures must ensure the identification of: Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.11.2
20.2.1 DOR.ICT.OPS.PRO.004	Secure configuration baselines for IT Assets, aimed at minimizing exposure to cyber threats, along with measures to regularly verify the effective deployment of these baselines. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 A.8.9
20.2.2 DOR.ICT.OPS.PRO.005	Security measures to ensure that only authorized software is installed on ICT Systems, End User Devices and Mobile Devices. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.11.2.c)
20.2.3 DOR.ICT.OPS.PRO.006	Security measures to ensure that only authorized ICT Systems and Devices are used to transfer and store data. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other

	Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.11.2.e)
20.3 DOR.ICT.OPS.PRO.007	Hardening baselines must be defined, documented, implemented and regularly reviewed for all infrastructure types in Red or Yellow Segregation Area. Asset-Types: Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.11.2.b)
20.4 DOR.ICT.OPS.PRO.008	As part of those procedures' requirements for a management solution for remote management and remote wipe of data of legal entity owned Mobile Devices must be established ensuring the following: – Remote wipe of business data stored on the Mobile Devices – LE owned Mobile Devices can be remotely disabled, erased, or locked Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
20.5 DOR.ICT.OPS.PRO.009	The procedures must include requirements for the use of security mechanisms that cannot be altered, removed, or circumvented by People or third-party ICT providers in an unauthorized manner. Asset-Types: Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection, Supplier Key References: DORA RTS RMF A.11.2.f).ii
20.6 DOR.ICT.OPS.PRO.010	The procedures must include requirements for the exclusive authorization of the use of removable media if the residual ICT risk is within the defined risk tolerance levels (in accordance with the ICT Risk Management Guideline). Asset-Types: Business Process, End User Device, Mobile Device, Storage Media, Other Device, Storage, Server & Host Hardware Key References: DORA RTS RMF A.11.2.f).iii
20.7 DOR.ICT.OPS.PRO.011	The implementation of security measures in the data and ICT System security procedure must ensure that remote-working and the use of private endpoint devices does not adversely impact ICT security. Asset-Types: Business Process, End User Device, Mobile Device, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection Key References: DORA RTS RMF A.11.2.j
20.8 DOR.ICT.OPS.PRO.012	Configurations of IT assets must be defined, documented, implemented, monitored, and reviewed. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other

	Device, Storage, Server & Host Hardware, Network Connection, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.9
20.9 DOR.ICT.OPS.PRO.013	The application of the defined configurations of IT Assets must be monitored during their entire lifetime, and deviations must be prevented or reported if they occur. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.9
20.10 DOR.ICT.OPS.PRO.014	ICT Systems must incorporate industry's best practices and vendors recommended security settings, where applicable. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Storage Media, Other Device, Storage, Server & Host Hardware, Network Connection, Supplier Key References: DORA RTS RMF A.11.2.k

ID: 21 (version 2.0)	Mobile Device Management
21 DOR.ICT.OPS.MDM.001	It must be ensured that mobile devices are managed.
21.1 DOR.ICT.OPS.MDM.002	All legal entity owned mobile devices, which have access to internal networks, network services and business information must be approved, registered, controlled, and managed for the use (for details on the Asset Inventory, please refer to the ICT Asset Management Guideline). Asset-Types: Information, Business Process, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
21.2 DOR.ICT.OPS.MDM.003	Security baselines must be defined for DBG-owned mobile devices and enforced through mobile device management (MDM). Asset-Types: Information, Business Process, Tool, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
21.3 DOR.ICT.OPS.MDM.004	Legal entity owned mobile devices must be kept up to date with all relevant security patches. Asset-Types: Information, Business Process, Tool, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
21.4	It must be ensured that all legal entity owned mobile devices only run on supported operating systems, i.e., devices are still maintained / receive

DOR.ICT.OPS.MDM.005	regular updates by the manufacturer and must not bypass any manufacturer usage restrictions (i.e. jailbreak or rooting). Asset-Types: Information, Business Process, Tool, Operating System, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
21.5 DOR.ICT.OPS.MDM.006	Vulnerabilities of legal entity owned mobile devices must be identified and managed accordingly to the ICT Patch and Vulnerability Management Guideline. Asset-Types: Information, Business Process, Tool, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
21.6 DOR.ICT.OPS.MDM.007	Legal entity owned mobile devices must be encrypted accordingly to the Encryption and Key Management Guideline. Asset-Types: Information, Business Process, Tool, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
21.7 DOR.ICT.OPS.MDM.008	Rules governing software installation on legal entity owned mobile devices must be defined and enforced to ensure only authorized applications are installed. Asset-Types: Information, Business Process, Tool, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
21.8 DOR.ICT.OPS.MDM.009	All legal entity owned mobile devices must be configured to ensure that the device cannot be compromised in the event of unauthorized physical access. At least the following actions must be ensured: – Pre-boot authentication must be enabled (only relevant for laptops) – USB ports must be disabled for mass storage media – Host-based firewall must be installed on all mobile devices and block all inbound traffic/connections except needed connections (relevant for laptops). Asset-Types: Information, Business Process, Tool, End User Device, Mobile Device, Storage Media, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
21.9 DOR.ICT.OPS.MDM.010	Legal entity owned mobile devices must be configured to ensure that the device cannot be compromised in the event of unauthorized physical access by at least enabling an automatic lock screen and a defined auto-lock timeout to automatically lock after a period of inactivity. Exemptions to this requirement are allowed but must be documented and substantiated by a justification. Asset-Types: Information, Business Process, Tool, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
21.10 DOR.ICT.OPS.MDM.011	It should be ensured that the mobile devices configuration settings can be recovered.

	Asset-Types: Information, Business Process, Tool, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
21.11 DOR.ICT.OPS.MDM.012	Where privately owned mobile devices (Bring-Your-Own-Devices) are approved to process and store data, appropriate controls must be implemented that ensure a separation of private and business usage supported by a software to protect business data on the private device (relevant for smartphones and tablets). Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Tool, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
21.12 DOR.ICT.OPS.MDM.013	The secure mobile device management (MDM) of privately-owned mobile devices must be in line with legal entity owned mobile devices. This implies at least the following: Asset-Types: Information, Business Process, Tool, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
21.12.1 DOR.ICT.OPS.MDM.014	Lock screen must be enabled, and auto-lock timeout must be defined to ensure that the mobile device is automatically locked after a period of inactivity Asset-Types: Business Process, End User Device, Mobile Device Key References: ISO 27001:2022 Cor 202203 A.8.1
21.12.2 DOR.ICT.OPS.MDM.015	Access to stored business data must automatically be locked in case of repeated entry of a wrong passcode (relevant for smartphones and tablets, in accordance with the Identity and Access Management Guideline) Asset-Types: Information, Business Process, End User Device, Mobile Device Key References: ISO 27001:2022 Cor 202203 A.8.1
21.13 DOR.ICT.OPS.MDM.016	Only authorized mobile devices must be connected to the internal network, excluding guest wi-fi. Asset-Types: Information, Business Process, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.1
21.14 DOR.ICT.OPS.MDM.017	Client operating systems must ensure that no unauthorized software can be run on a client system Asset-Types: Information, Business Process, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Server & Host Hardware, Network Connection Key References: § 8a (1) BSIG 55, ISO 27001:2022 Cor 202203 A.8.1
21.15 DOR.ICT.OPS.MDM.018	Access to data in the Red and Yellow Segregation Area must be restricted to legal entity owned devices. Access to data in the Blue and Green Segregation Area should be restricted to legal entity owned devices.

	Asset-Types: Information, Business Process, End User Device, Mobile Device Key References: § 8a (1) BSIG 55, ISO 27001:2022 Cor 202203 A.8.1
--	---

ID: 22 (version 2.0)	Secure use
22 DOR.ICT.OPS.USE.001	It must be ensured that end users work and communicate securely.
22.1 DOR.ICT.OPS.USE.002	End users working outside of legal entity's premises including travelling must be aware of the specific risks of remote work and related security requirements. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.7.9
22.2 DOR.ICT.OPS.USE.003	End users must comply with the following requirements: Lost and returned mobile devices must be returned for inspection of manipulation and malicious code. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.7.9
22.3 DOR.ICT.OPS.USE.004	The following actions must not be performed unless they are required for business purposes, for which an approval process must be defined: – Make any changes to the software installed on their legal entity owned devices. – Download, store, install or run any executable files of external sources. – Make any physical changes to the IT assets. – The security configuration / security measures of IT assets provided by the legal entity must not be changed, disabled, or bypassed. – Download, store, install, or run any programs or executable files from sources other than legal entity internal trusted sources. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.5.10

ID: 23 (version 2.0)	Anti-malware solution
23 DOR.ICT.OPS.MAL.001	It must be ensured that endpoints are protected against malware.
23.1 DOR.ICT.OPS.MAL.002	Approved anti-malware protection must be installed on all endpoints if technically feasible. Asset-Types: Information, Business Process, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.7

23.2 DOR.ICT.OPS.MAL.003	The anti-malware solution must include: – Anti-malware protection to ensure that all running software, data and/or connections are protected from malicious code – NIDS and NIPS to ensure that all network traffic between network security zones is analyzed to ensure attacks or misuse are actively prevented – HIPS and HIDS to ensure infrastructure components are protected against malicious system integrity changes, where technically applicable, or at least to monitor malicious behavior and report it as a security event – Sufficient options to connect the solution to the monitoring solution (SIEM or equivalent at the legal entity) Asset-Types: Information, Business Process, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Server & Host Hardware, Network Connection Key References: ISO 27001:2022 Cor 202203 A.8.7
23.3 DOR.ICT.OPS.MAL.004	The anti-malware solution must always be active when the system is running. Asset-Types: Information, Business Process, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Server & Host Hardware, Operating System Key References: ISO 27001:2022 Cor 202203 A.8.7
23.4 DOR.ICT.OPS.MAL.005	Anti-malware solutions must always be up to date. Asset-Types: Information, Business Process, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.7
23.5 DOR.ICT.OPS.MAL.006	Anti-malware protection must check all files on endpoints. Asset-Types: Information, Business Process, End User Device, Mobile Device Key References: ISO 27001:2022 Cor 202203 A.8.7
23.6 DOR.ICT.OPS.MAL.007	Anti-malware protection on servers must at least scan all transferred files. Asset-Types: Information, Business Process, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Server & Host Hardware, Self-developed Application Key References: ISO 27001:2022 A.8.7
23.7 DOR.ICT.OPS.MAL.008	Signatures or equivalent for next-gen protection (IOC,IOA9 must be updated regularly. Asset-Types: Business Process Key References: ISO 27001:2022 A.8.7
23.8 DOR.ICT.OPS.MAL.009	Security solutions must be approved by the 1st LoD. Asset-Types: Business Process Key References: ISO 27001:2022 Cor 202203 A.8.7

ID: 24 (version 2.0)	Clock Synchronization
24 DOR.ICT.OPS.CLK.001	It must be ensured that the time settings of all IT assets are synchronized and managed.
24.1 DOR.ICT.OPS.CLK.002	A standard reference time for use by all information systems must be defined. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.17
24.2 DOR.ICT.OPS.CLK.003	The clocks of all relevant information processing systems within an organization or security domain must be synchronized to a single reference time source. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Supplier Key References: ISO 27001:2022 Cor 202203 A.8.17
24.3 DOR.ICT.OPS.CLK.004	Clock synchronization process must be logged by the information system. Failure to reach the time server or to synchronize time must be automatically reported as a security event. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.17
24.4 DOR.ICT.OPS.CLK.005	UTC+00:00 must be assigned as the time zone for all log data, if possible. Asset-Types: Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware Key References: ISO 27001:2022 Cor 202203 A.8.17

ID: 25 (version 2.0)	Use of email accounts
25 DOR.ICT.OPS.EMA.001	It must be ensured that email accounts are used in a secure way.
25.1 DOR.ICT.OPS.EMA.002	Email accounts must be used for business purposes only and following requirements must be fulfilled: Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.10

25.1.1 DOR.ICT.OPS.EMA.003	Emails must not be automatically forwarded to external email addresses. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.10
25.1.2 DOR.ICT.OPS.EMA.004	Links (hyperlinks) or attachments in emails whose sender or content does not appear to be trustworthy must not be clicked and must be reported to Cyber Emergency Response Team (CERT). Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.10
25.1.3 DOR.ICT.OPS.EMA.005	Unsolicited emails should be forwarded to CERT (CERT@deutsche-boerse.com) for further investigation. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.10
25.1.4 DOR.ICT.OPS.EMA.006	Email pop-ups should be turned off during presentations, screen sharing or in a public area. Asset-Types: Information, Business Process Key References: ISO 27001:2022 Cor 202203 A.5.10

ID: 26 (version 2.0)	Internet usage
26 DOR.ICT.OPS.INT.001	It must be ensured that internet is used in a secure way.
26.1 DOR.ICT.OPS.INT.002	End users must not use company provided internet access (incl. private browser) for: Asset-Types: Information, Business Process, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.10
26.1.1 DOR.ICT.OPS.INT.003	Any activity that is against the legal entity's code of conduct, which includes any illegal activities. Asset-Types: Information, Business Process, End User Device, Mobile Device Key References: ISO 27001:2022 Cor 202203 A.5.10
26.1.2 DOR.ICT.OPS.INT.004	Downloading data that is not approved and licensed for business within legal entity. Asset-Types: Information, Business Process, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.10
26.1.3 DOR.ICT.OPS.INT.005	Attempting to gain unauthorized access to external networks or servers. Asset-Types: Information, Business Process, End User Device, Mobile Device, Network Connection Key References: ISO 27001:2022 Cor 202203 A.5.10

5. Roles and Responsibilities

5.1. Creator

The creator of the ICT Operations Guideline is the ICT Risk Governance & Advisory Unit (Specialist).

The creator of ICT Operations Guideline has the responsibility to issue clear, precise, and appropriate written rules to give guidance for implementation to the target group. It is important to ensure that all required information is accurate, up to date and complete.

5.2. Guideline Owner

The owner of the ICT Operations Guideline is Head of ICT Risk Governance & Advisory Unit.

The most important tasks (not an exhaustive list) within the scope of responsibility are:

- Ensure completeness of the Guideline within functional area of responsibility
- Ensure correctness of content and the Guideline is up to date
- Define and conduct adherence oversight measures for Guidelines on a regular basis
- Assess impact on the Guideline with major focus on requirements as well as roles and responsibilities in the event of organizational changes, new products etc.

The Guideline Owner has at least an Expert or Head of Unit level.

The Guideline Owner is responsible for publishing and updating the ICT Operations Guideline according to established procedures within the organization.

6. Appendix

6.1. Contact Information

Written Rule Owner: Head of ICT Risk Governance & Advisory Unit

Please contact ICT Risk **Governance & Advisory** in case of any questions related to this Guideline.

6.2. Document History

Document History

Version	Date	Changes & Background
1.0	17.01.2025	Initial set-up of this Guideline
1.1	15.08.2025	Annual Update Guideline
2.0	19.08.2026	Annual Update with material changes

Coordination before publication

Version	Date	Task	Name
2.0	15.05.2026	Creator	ICT Risk Governance & Advisory Unit (Specialist)
	28.07.2026	Content Review	LE CISOs TISOs IT Ameli project
	28.07.2026	Content Confirmation	Head of ICT Risk Governance & Advisory Unit and LE CISOs

Approvals

Version	Date	Task	Name
2.0	13.08.2026	Approval	DBAG Chief Risk Officer

6.3. Related Written Rules

Superordinated Written Rules	ICT Risk Management Policy
Subordinated Written Rules	n/a

6.4. Abbreviations

The abbreviations in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

***** END OF DOCUMENT *****
